

# Flujo de Autenticación

App Dabeliz · Control de Producción

Google Sign-In + Firebase Authentication + Roles en Firestore

**Para ti, junior:** este documento explica cómo entra un usuario a nuestra app, qué piezas intervienen, por qué cada una existe y qué hacer cuando algo falla. Léelo completo una vez; después úsalo como guía de consulta. Todo lo que está aquí lo vivimos configurando este proyecto, errores incluidos.

# 1. La idea en 30 segundos

Autenticar y autorizar son dos cosas distintas, y nuestra app hace las dos:

| Concepto      | Pregunta que responde | Quién lo resuelve                                |
|---------------|-----------------------|--------------------------------------------------|
| Autenticación | ¿Quién eres?          | Google + Firebase Authentication                 |
| Autorización  | ¿Qué puedes hacer?    | Tu <b>rol</b> en Firestore + Reglas de seguridad |

En corto: el usuario demuestra quién es con su cuenta de Google, Firebase le da un identificador único (**UID**), y con ese UID buscamos su documento en `usuarios/{uid}` para saber su rol. Esta app solo deja pasar a **admin**; la futura app del trabajador dejará pasar a **trabajador**.

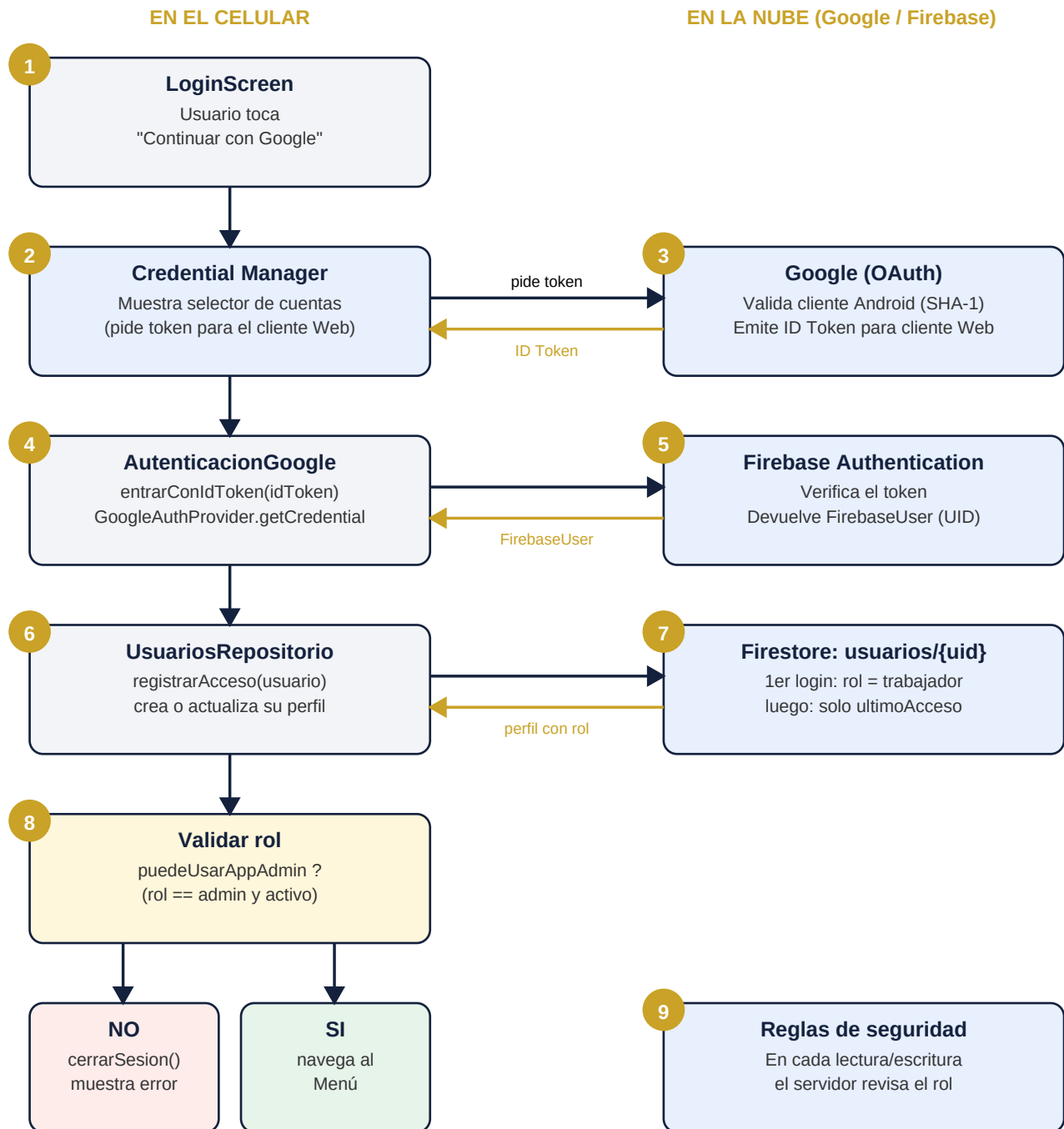
**Regla de oro:** la app puede *ocultar* cosas, pero quien realmente *protege* los datos son las **Reglas de seguridad** en el servidor. Una app se puede modificar; las reglas no.

# 2. Las piezas del rompecabezas

| Pieza                             | Dónde vive                                           | Para qué sirve                                                                                                                                                        |
|-----------------------------------|------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Cliente OAuth <b>Android</b>      | Google Cloud (se crea al poner el SHA-1 en Firebase) | Demuestra que la app que pide el login es la nuestra: paquete <code>com.dabeliz.card</code> + huella SHA-1 de la llave que la firmó.                                  |
| Cliente OAuth <b>Web</b>          | Google Cloud                                         | Es el <i>destinatario</i> del token. Google emite el ID Token para este cliente y Firebase solo acepta tokens dirigidos a él. <b>Obligatorio</b> para Google Sign-In. |
| <code>google-services.json</code> | app/ (NO se sube a git)                              | Configuración del proyecto Firebase. Se convierte en recursos al compilar. Es una foto: si cambias algo en la consola, hay que descargarlo de nuevo.                  |
| Firebase Authentication           | Firebase                                             | Verifica el token de Google, crea el usuario y le da un UID. Recuerda la sesión en el celular.                                                                        |
| Colección <code>usuarios</code>   | Firestore                                            | Un documento por cuenta con su rol y si está activa.                                                                                                                  |
| Reglas de seguridad               | Firestore y Storage                                  | El servidor revisa el rol en cada lectura/escritura.                                                                                                                  |

### 3. El flujo completo, paso a paso

Los números dorados corresponden a la explicación de la página siguiente.



## Explicación de cada paso

| #   | Qué pasa                                                                                                                                                    | Dónde está en el código               |
|-----|-------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|
| 1   | El usuario toca <b>Continuar con Google</b> .                                                                                                               | LoginScreen.kt · TarjetaAcceso()      |
| 2   | Credential Manager abre el selector de cuentas. Le pasamos el <b>Web client ID</b> (lo lee de default_web_client_id o, si falta, de strings.xml).           | AutenticacionGoogle.iniciarSesion()   |
| 3   | Google verifica que la app esté firmada con un SHA-1 registrado y emite un <b>ID Token</b> (un JWT firmado por Google) cuyo destinatario es el cliente Web. | Google, no es código nuestro          |
| 4   | Convertimos ese token en una credencial de Firebase.                                                                                                        | entrarConIdToken()                    |
| 5   | Firebase valida el token y devuelve un <b>FirebaseUser</b> con su UID. La sesión queda guardada en el celular: al reabrir la app entra directo al menú.     | auth.signInWithCredential()           |
| 6-7 | Leemos o creamos usuarios/{uid}. Si es la primera vez, se crea con <b>rol = trabajador</b> (las reglas prohíben crearse como admin).                        | UsuariosRepositorio.registrarAcceso() |
| 8   | Si el rol no es admin o la cuenta está inactiva: cerramos sesión y mostramos el motivo. Si es admin: navegamos al menú.                                     | Usuario.puedeUsarAppAdmin             |
| 9   | A partir de aquí, cada lectura o escritura en Firestore/Storage pasa por las reglas, que vuelven a revisar el rol en el servidor.                           | firestore.rules · storage.rules       |

## Plan B: el flujo clásico

Credential Manager necesita Google Play Services 23.08 o más nuevo. En celulares o emuladores viejos lanza *"no provider dependencies found"*. En ese caso `iniciarSesion()` devuelve `UsarFlujoClasico` y la pantalla abre el selector clásico de `play-services-auth`. Los dos caminos terminan en el mismo `entrarConIdToken()`, así que el resto del flujo es idéntico.

## Cerrar sesión

`cerrarSesion()` hace tres cosas: cierra Firebase (`auth.signOut()`), limpia Credential Manager y cierra el cliente clásico. Si no limpiáramos los dos últimos, el celular entraría automáticamente con la misma cuenta.

## 4. Roles y permisos

Documento en Firestore:

```
usuarios/RDqnEIFLEVgtoGqMAMzBrSqssSx1
  email: "...@gmail.com"
  nombre: "Jorge Daniel Lizana Ventura"
  rol: "admin" // "admin" | "trabajador"
  activo: true
  creadoEn, ultimoAcceso: timestamps del servidor
```

| Quién           | usuarios                                        | modelos (Firestore) | Fotos (Storage)                    |
|-----------------|-------------------------------------------------|---------------------|------------------------------------|
| Sin sesión      | Nada                                            | Nada                | Nada                               |
| Trabajador      | Solo su documento; no puede tocar rol ni activo | Solo leer           | Solo ver                           |
| Admin           | Ver todos, cambiar rol y activo                 | Leer y escribir     | Subir (imagen, máx. 5 MB) y borrar |
| Cuenta inactiva | Solo su documento                               | Nada                | Nada                               |

**¿Cómo se crea el primer admin?** Nadie puede auto-asignarse admin (las reglas lo impiden). El primero se pone a mano en la consola de Firestore, que no pasa por las reglas. Desde ahí, ese admin asigna roles a los demás desde **Menú > Usuarios y Roles**.

**Protección anti-accidente:** en la pantalla de usuarios no puedes cambiar tu propio rol ni desactivarte, para que no te quedes fuera de la app.

## 5. Errores que nos encontramos (y cómo leerlos)

Tip de jefe: antes de tocar código, pregúntate **en qué paso del diagrama** falla. Si el error sale antes del paso 5, el problema es de configuración en Google/Firebase, no de Firestore ni de tu código.

| Mensaje                                                   | Causa real                                                                                 | Solución                                                                                                          |
|-----------------------------------------------------------|--------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| "Falta el cliente web de Google en google-services.json"  | El JSON no traía <code>client_type: 3</code> .                                             | Revisar que exista el cliente Web; descargar de nuevo el JSON o poner el ID en <code>strings.xml</code> .         |
| <b>getCredentialAsync: no provider dependencies found</b> | Emulador con Google Play Services de 2022 (22.50). Credential Manager necesita 23.08+.     | Agregamos el flujo clásico como plan B. O actualizar Play Services.                                               |
| <b>[28444] Developer console is not set up correctly</b>  | Firebase apuntaba a un cliente Web (...fvd93bb1...) que <b>no existía</b> en Google Cloud. | Crear el cliente Web en Google Cloud y ponerlo en Firebase > Authentication > Google > Configuración del SDK web. |
| Código 10 (DEVELOPER_ERROR)                               | El SHA-1 de la llave que firmó el APK no está registrado.                                  | Agregar ese SHA-1 en Firebase. Ojo: cada PC tiene su propia llave debug, y release es otra.                       |
| "No tiene rol de administrador"                           | <b>No es un error:</b> el login funcionó y la cuenta es trabajador.                        | Cambiar rol a admin (consola o pantalla Usuarios).                                                                |
| "No se pudo leer tu perfil: PERMISSION_DENIED"            | Las reglas de Firestore no permiten la operación.                                          | Revisar <code>firestore.rules</code> y que estén publicadas.                                                      |

## 6. Checklist para un proyecto nuevo

|     | Paso                                                                                                                                                                                                     |
|-----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [ ] | Crear el proyecto en Firebase y registrar la app Android con su <b>paquete</b> .                                                                                                                         |
| [ ] | Obtener el SHA-1: <code>keytool -list -v -keystore ~/.android/debug.keystore -alias androiddebugkey -storepass android</code> . Agregarlo en Configuración del proyecto (y el de release cuando exista). |
| [ ] | Authentication > Método de acceso > <b>Google</b> > Habilitar (con correo de asistencia).                                                                                                                |
| [ ] | Google Cloud > Google Auth Platform: pantalla de consentimiento configurada y público <b>En producción</b> (o usuarios de prueba agregados).                                                             |
| [ ] | Google Cloud > Clientes: verificar que existan <b>Android</b> y <b>Web</b> .                                                                                                                             |
| [ ] | Descargar <code>google-services.json</code> y confirmar que trae <code>"client_type": 3</code> .                                                                                                         |
| [ ] | Firestore y Storage: reemplazar las reglas de <b>modo de prueba</b> (vencen a los 30 días y dejan todo abierto).                                                                                         |
| [ ] | Primer login, luego asignar el primer admin a mano en la consola.                                                                                                                                        |

## 7. Glosario rápido

| Término             | Qué significa                                                                              |
|---------------------|--------------------------------------------------------------------------------------------|
| UID                 | Identificador único que Firebase le da a cada usuario. Es el id del documento en usuarios. |
| ID Token            | Documento firmado por Google (JWT) que dice "esta persona es X". Dura ~1 hora.             |
| SHA-1               | Huella digital de la llave con la que se firma el APK. Así Google sabe que la app es tuya. |
| Client ID           | Identificador público de un cliente OAuth. <b>No es secreto</b> ; puede ir en la app.      |
| Client secret       | Clave privada del cliente Web. <b>Nunca</b> va en la app; solo en Firebase.                |
| Credential Manager  | API moderna de Android para iniciar sesión (passkeys, contraseñas, Google).                |
| Reglas de seguridad | Código que corre en el servidor de Firebase y decide si cada operación se permite.         |

**Mapa de archivos:** `ui/login/AutenticacionGoogle.kt` (flujo) · `ui/login/LoginScreen.kt` (pantalla) · `data/UsuariosRepositorio.kt` (perfil y roles) · `model/Usuario.kt` (Rol) · `ui/usuarios/UsuariosScreen.kt` (gestión) · `firestore.rules` · `storage.rules` · `res/values/strings.xml` (`google_web_client_id`)